

IA & CYBERSÉCURITÉ

Sécuriser l'IA • Utiliser l'IA pour sécuriser • Maîtriser les dépendances

01 IA pour la sécurité

Analyse, détection, corrélation, réponse aux incidents.

02 Sécurité pour l'IA

Données, modèles, prompts, API, supply chain et hardware.

03 Régulation & souveraineté

AI Act, CRA, CSA 2.0, dépendances et résilience stratégique.

04 IA pour la sécurité

Analyse, détection, corrélation, réponse aux incidents.

PARTIE 1

Repenser la sécurité avec & pour l'IA

Synthèse visuelle construite à partir des documents fournis

Trois questions structurent tout le sujet

Une lecture simple pour relier technique, gouvernance et régulation.

1. Que peut apporter l'IA ?

Comprendre des données complexes, extraire des informations, détecter des anomalies, corréler des événements et accélérer la réponse.

2. Comment protéger l'IA ?

Sécuriser données, modèles, prompts, API, connecteurs, agents, hardware et chaîne d'approvisionnement.

3. Qui gouverne et qui dépend de qui ?

Attribuer les privilèges, définir les responsabilités, contrôler les fournisseurs et maintenir la souveraineté numérique.

La sécurité de l'IA devient un problème à la fois technique, organisationnel et stratégique.

La sécurité dépasse largement la cybersécurité

Elle protège la continuité, la résilience et la souveraineté.

GEO Géopolitique

Espionnage, ingérence, sabotage
Protège : Souveraineté, institutions

ECO Économique

Fraude, ransomware, dépendance
Protège : Innovation, compétitivité

SOC Sociétal

Désinformation, données personnelles
Protège : Confiance, stabilité sociale

CPS Systèmes critiques

Énergie, eau, santé, transport
Protège : Continuité des services

IT Cyber

Phishing, malware, DDoS
Protège : SI, données, services

PHY Physique

Intrusion, vol, coupure
Protège : Datacenters, équipements

La sécurité moderne vise autant à prévenir l'attaque qu'à continuer à fonctionner malgré elle.

IA et cybersécurité : une relation dans les deux sens

L'IA renforce la défense, mais devient elle-même un actif critique.



Sans gouvernance, on peut avoir une IA performante et pourtant dangereuse à exploiter.

Ce que l'IA apporte à la cybersécurité

Trois capacités simples, mais puissantes.

A Comprendre

Analyser rapidement des volumes importants de données hétérogènes et faire ressortir tendances, signaux faibles et anomalies.

B Extraire

Repérer automatiquement les informations utiles dans des logs, rapports, emails ou bases de données.

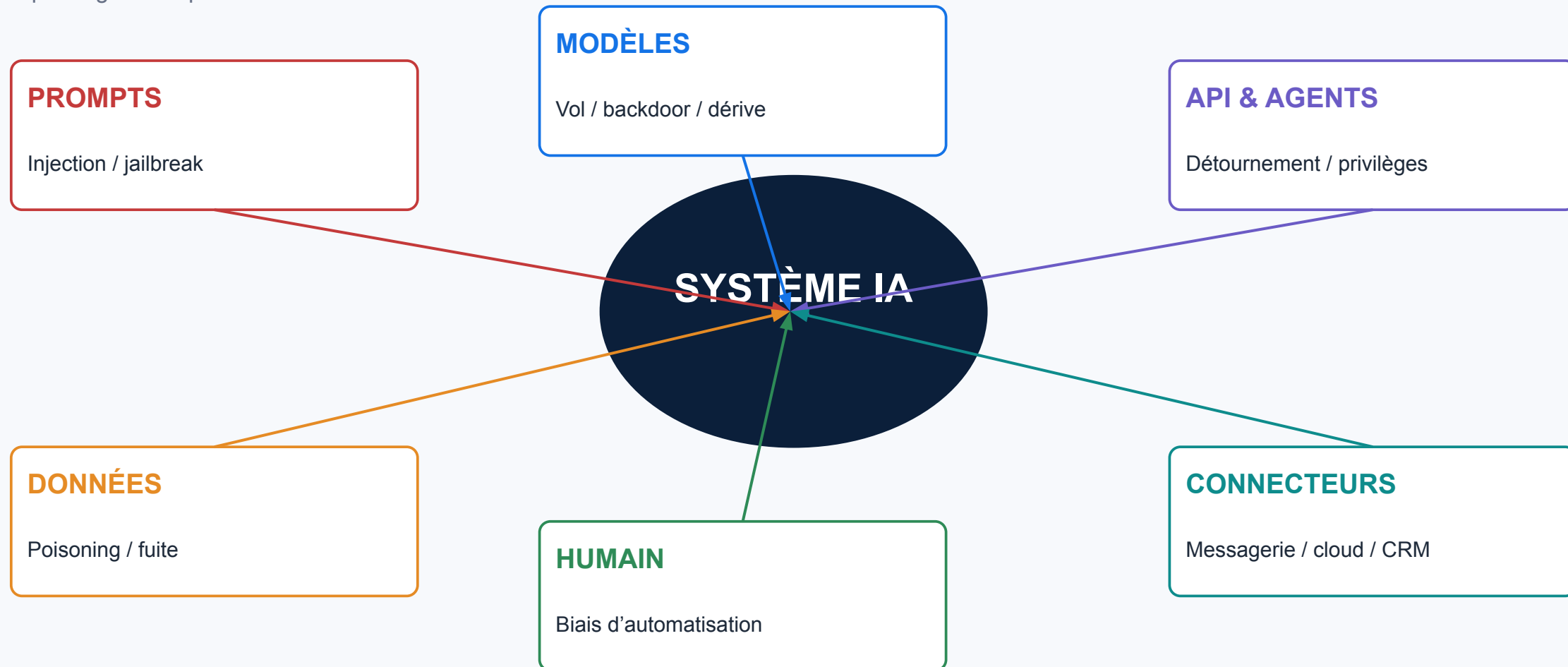
C Faire correspondre

Comparer une situation à des règles, politiques internes, référentiels ou exigences de conformité.

- Exemples**
- Corréler des alertes SIEM
 - Extraire IP / comptes / vulnérabilités
 - Vérifier une configuration face à une politique interne

L'IA ajoute de nouvelles surfaces d'attaque

Le risque augmente quand l'IA est connectée à des données et à des actions.



Plus une IA a accès à des données et à des actions, plus ses permissions doivent être limitées et surveillées.

L'IA en offensif : industrialiser, personnaliser, accélérer

Même technologie, finalités opposées.

PH Hameçonnage

Messages crédibles et personnalisés → Vol d'identifiants / fraude

DF Deepfake

Voix, image ou vidéo réaliste → Usurpation / manipulation

MW Malware & exploits

Aide à l'analyse et l'adaptation de code → Industrialisation des attaques

VUL Découverte de vulnérabilités

Repérage accéléré de faiblesses → Réduction du temps jusqu'à l'exploitation

L'IA réduit surtout le coût, le temps et le niveau de spécialisation nécessaires pour certaines attaques.

Jailbreak, prompt injection et empoisonnement

Trois attaques à ne pas confondre.

JB Jailbreaking

Contourner les règles du modèle en reformulant ou en construisant un scénario qui pousse l'IA à ignorer ses restrictions.

PI Prompt injection

Faire suivre à l'IA une instruction malveillante, parfois cachée dans une page Web, un PDF ou un email.

DP Data poisoning

Introduire de mauvaises données pour modifier ce que le modèle apprend ou considère comme normal.

Jailbreak = contourner les règles • Prompt injection = détourner les instructions • Poisoning = corrompre l'apprentissage.

Modèles externes : le risque “supply chain”

Télécharger un modèle revient aussi à faire confiance à un composant logiciel.



Risques

- Exécution de code non maîtrisé
- Vol de secrets ou accès locaux
- Rebond vers d'autres services
- Backdoor ou modèle compromis

Mesures

- Vérifier provenance et réputation
- Préférer des formats sûrs
- Scanner et isoler l'exécution
- Appliquer le moindre privilège

Un modèle IA doit être traité comme une dépendance logicielle potentiellement non fiable.

Le vrai point dur : double usage, dérive en production et privilèges

La technologie n'est qu'une partie du risque.

Double usage

La même IA peut détecter une attaque ou aider à la préparer.

La frontière défense / offensive dépend du contexte et de l'usage.

Évolution des modèles

Une mise à jour ou un changement de données peut modifier le comportement du modèle en production.

Régression, dérive, faux positifs.

Humain & privilèges

C'est l'humain qui décide ce que l'agent peut lire, écrire ou exécuter.

Moindre privilège + validation humaine.

La gouvernance devient le garde-fou qui relie performance, sécurité et responsabilité.

PARTIE 2

Régulation, souveraineté et dépendances

Synthèse visuelle construite à partir des documents fournis

La cybersécurité est partout

Elle protège les services essentiels, les organisations et désormais les systèmes d'IA.

01 Administrations

Services publics, données citoyens

02 Santé

Dossiers patients, dispositifs

03 Énergie

Production et distribution

04 Transports

Réseaux et infrastructures

05 Finance

Transactions et résilience

06 Télécoms

Connectivité et DNS

07 Industrie

OT / SCADA / production

08 IA

Modèles, prompts, agents

La surface réglementaire s'étend avec la numérisation : produit, service, donnée, cloud, IA, fournisseur.

Panorama des principaux textes

Chaque texte protège une “brique” différente du système numérique.

RGPD

Données personnelles
→ 2018

NIS2

Organisations essentielles
→ Cyber

DORA

Finance
→ Résilience

AI Act

Systèmes d'IA
→ Risque

CRA

Produits numériques
→ Security by design

CSA

Certification cyber
→ Confiance

Le défi n'est plus seulement d'avoir des règles, mais de faire fonctionner ensemble des textes qui se chevauchent.

Avec l'IA, de nouveaux objets deviennent réglementaires

La conformité ne s'arrête plus au logiciel final.

1 Modèles

Actif critique à protéger

2 Données d'entraînement

Qualité, provenance, poisoning

3 Prompts / contexte

Nouvelle entrée du système

4 Agents autonomes

Capacité d'agir

5 API / connecteurs

Accès à des services tiers

6 Supply chain IA

Modèles, libs, cloud, fournisseurs

L'objet à sécuriser devient un écosystème : modèle + données + outils + fournisseurs + infrastructure.

AI Act : contrôle interne et évaluation par un tiers

Le niveau de contrôle dépend du type de système et du cadre applicable.

Contrôles internes

- Gestion des risques
- Cybersécurité
- Qualité des données
- Documentation technique
- Tests et validation
- Journalisation / traçabilité
- Supervision humaine
- Surveillance après déploiement

Third-party assessment

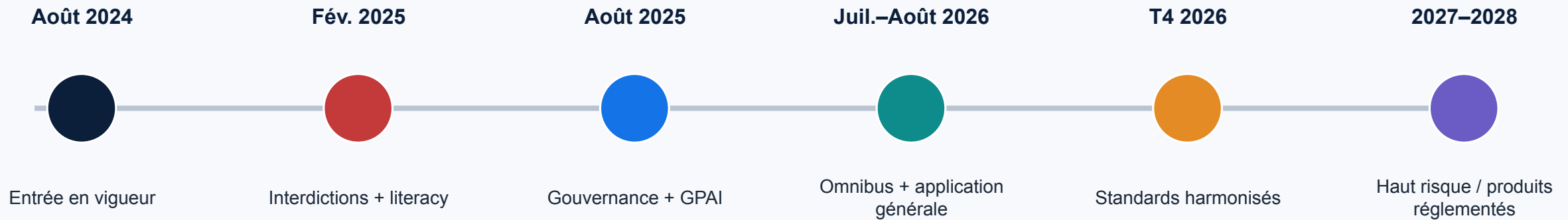
- Vérification indépendante
- Audit du système de management qualité
- Revue de la documentation technique
- Intervention d'un organisme notifié lorsque le règlement l'exige

Important : l'évaluation externe ne transfère pas la responsabilité du fournisseur.

Conformité = preuve documentée, tests, traçabilité et responsabilité, pas seulement “un modèle qui fonctionne”.

AI Act : calendrier et harmonisation des standards

Le droit avance d'abord, les standards techniques viennent ensuite préciser comment démontrer la conformité.



Une norme devient “harmonisée” lorsqu’elle est référencée au JOUE, ce qui ouvre une présomption de conformité.

Digital Omnibus : deux propositions, deux trajectoires

Objectif commun : réduire les chevauchements et rendre le corpus numérique plus cohérent.

AI Omnibus

Cible principalement l'AI Act.

- Clarification des obligations
- Ajustement du calendrier
- Simplification pour certaines entreprises
- Décalage de certains régimes haut risque

Digital Omnibus général

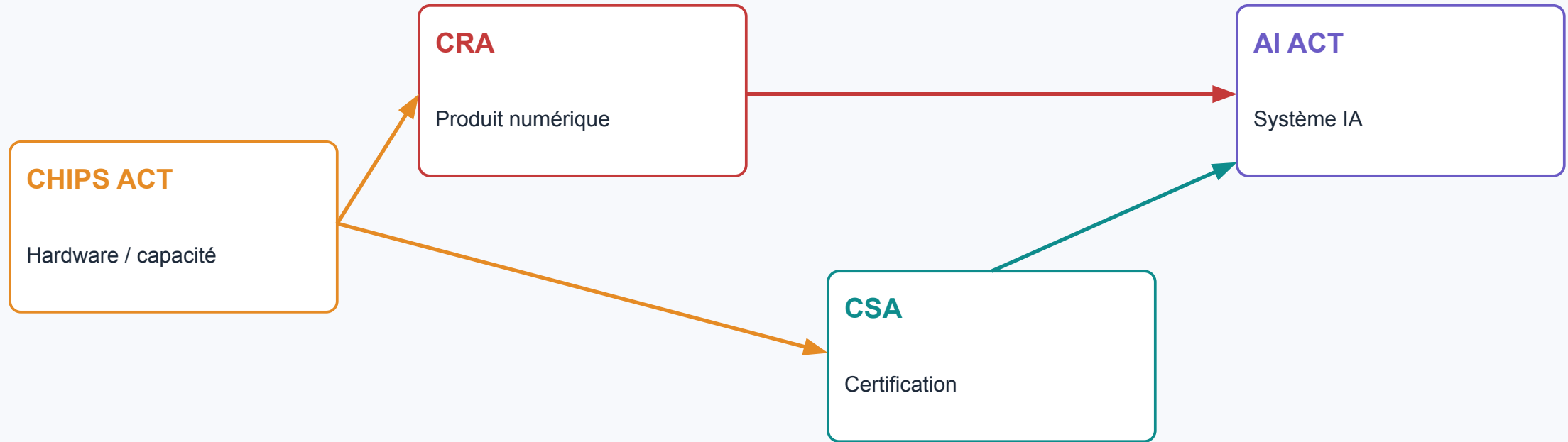
Cible données, cyber, vie privée et règles numériques.

- Réduction des doublons
- Reporting plus cohérent
- Articulation RGPD / Data Act / ePrivacy / CRA / NIS2

Le but n'est pas de supprimer le cadre, mais d'éviter que conformité et cybersécurité deviennent un empilement incohérent.

Les connexions manquantes entre les textes

Le problème européen : des briques solides, mais des ponts encore incomplets.

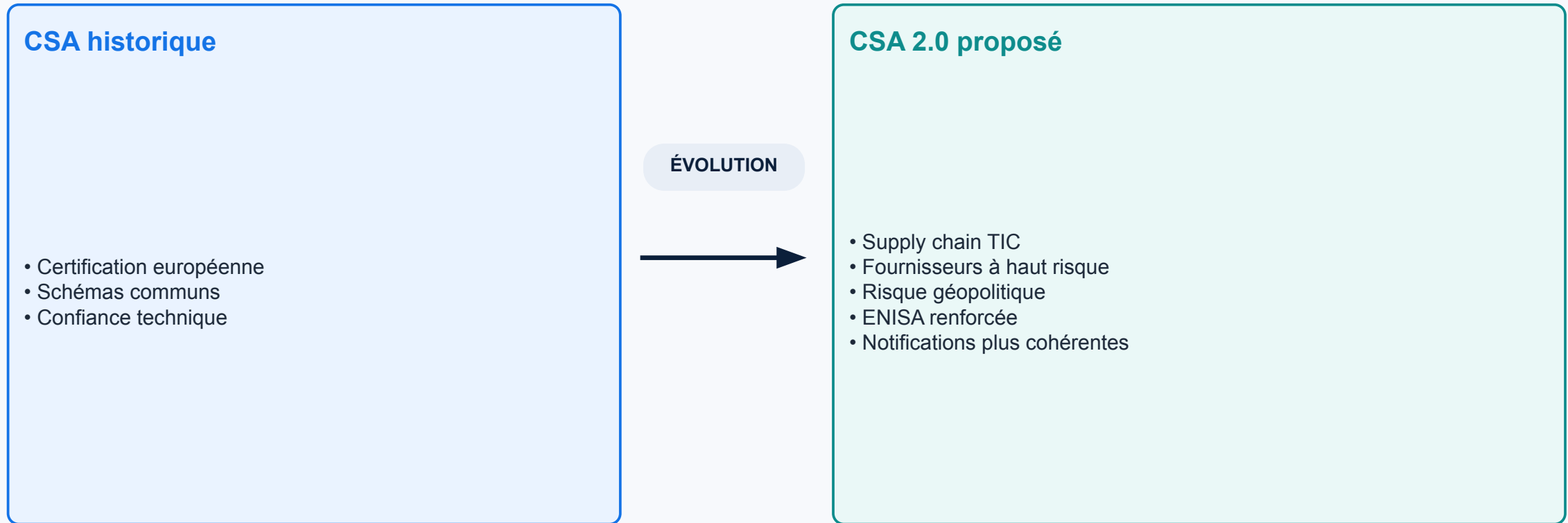


Ponts à consolider

- AI Act ↔ CRA : modèle vs produit
- CSA ↔ CRA : certification vs exigences obligatoires
- CSA ↔ AI Act : cybersécurité vs conformité IA
- Chips Act ↔ AI Act : capacité matérielle vs gouvernance

CSA 2.0 : faire de la certification un outil stratégique

La proposition élargit la logique du Cybersecurity Act au risque fournisseur et à la supply chain.



Le changement : ne plus demander seulement “est-ce sécurisé ?”, mais aussi “de qui dépend-on ?”.

SecNumCloud 3.2 : sécurité + confiance + maîtrise juridique

Le référentiel français vise un haut niveau de sécurité des services cloud.

1

Sécurité technique

Architecture, accès, supervision

2

Protection juridique

Réduction du risque extraterritorial

3

Traçabilité

Logs, audit, administration

4

Continuité

Sauvegardes, reprise, résilience

5

Sous-traitants

Maîtrise de la chaîne de service

6

IaaS / PaaS / SaaS

Plusieurs niveaux de cloud

En 2026, l'enjeu devient aussi européen : articulation avec EUCS et harmonisation de la confiance cloud.

5G Toolbox : le tournant vers le risque fournisseur

La sécurité devient aussi géopolitique et systémique.

5G Toolbox

Risques pris en compte :

- Dépendance à un fournisseur
- Fournisseur à haut risque
- Concentration du marché
- Supply chain
- Espionnage / sabotage
- Virtualisation et cloud
- Risque géopolitique

Exemple : onduleur solaire connecté

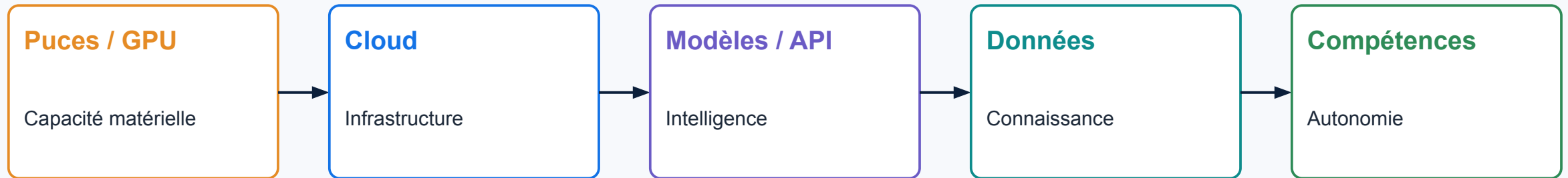
Un onduleur peut dépendre du fabricant, de son cloud et de mises à jour distantes.

Si un grand parc est compromis ou désactivé simultanément, l'impact n'est plus local : il peut devenir systémique pour le réseau électrique.

Le bon réflexe : analyser non seulement le produit, mais aussi qui le contrôle, où et à quelle échelle.

Dépendances stratégiques : le risque non technique

Une organisation peut être vulnérable sans aucune faille logicielle.



Risques associés

- Vendor lock-in et hausse des coûts
- Rupture d'approvisionnement ou sanctions
- Conflits de juridiction
- Perte de maîtrise des données
- Érosion des compétences internes

Réponse européenne

- Diversification des fournisseurs
- Stratégies de sortie
- Souveraineté cloud / data
- Chips Act 2.0 pour renforcer la base matérielle

Le risque stratégique, c'est aussi de ne plus pouvoir décider, migrer ou remplacer.

PARTIE 3

IA embarquée, Security & Safety

Synthèse visuelle construite à partir des documents fournis

Système embarqué vs système cyber-physique

L'un exécute une fonction dans un objet ; l'autre boucle en permanence avec le monde réel.

Système embarqué

Informatique intégrée dans un appareil pour réaliser une fonction précise.

Exemples : calculateur automobile, drone, montre connectée, appareil médical.

Contraintes : temps réel, consommation, fiabilité, taille.

Système cyber-physique (CPS)

Capteurs → logiciel / IA → décision → actionneurs → monde physique.

Exemples : voiture autonome, robot industriel, smart grid, chaîne automatisée.

Une cyberattaque peut donc avoir une conséquence physique.

Dans un CPS, une décision logicielle devient une action réelle.

BLERP : choisir entre Edge et Cloud

Cinq critères structurent la décision d'exécuter l'IA localement ou à distance.



Bandwidth

Volume à transmettre



Latency

Temps de réponse



Economics

Coût calcul / cloud / réseau



Reliability

Fonctionner sans connexion



Privacy

Données peuvent-elles sortir
?

EDGE / local

Faible latence • autonomie • confidentialité

CLOUD

Puissance mutualisée • élasticité • centralisation

Security vs Safety

Deux questions différentes, mais inséparables dans les CPS.

SECURITY

Protection contre les attaques et actions malveillantes.

Question : “Quelqu’un peut-il attaquer le système ?”

Objectifs : confidentialité, intégrité, disponibilité, contrôle des accès.

Exemple : prise de contrôle à distance d'un véhicule.

SAFETY

Protection contre accidents, pannes et comportements dangereux.

Question : “Le système peut-il provoquer un dommage ?”

Objectifs : éviter dommages aux personnes, équipements et environnement.

Exemple : capteur défectueux qui empêche le freinage.

Une faille de Security peut déclencher un problème de Safety.

Attaquer une IA embarquée : données, modèle et matériel

Le point d'entrée peut être très différent selon le scénario.

DONNÉES

Data poisoning
Adversarial examples
Backdoor triggers

MODÈLE

Model poisoning
Extraction
Inversion

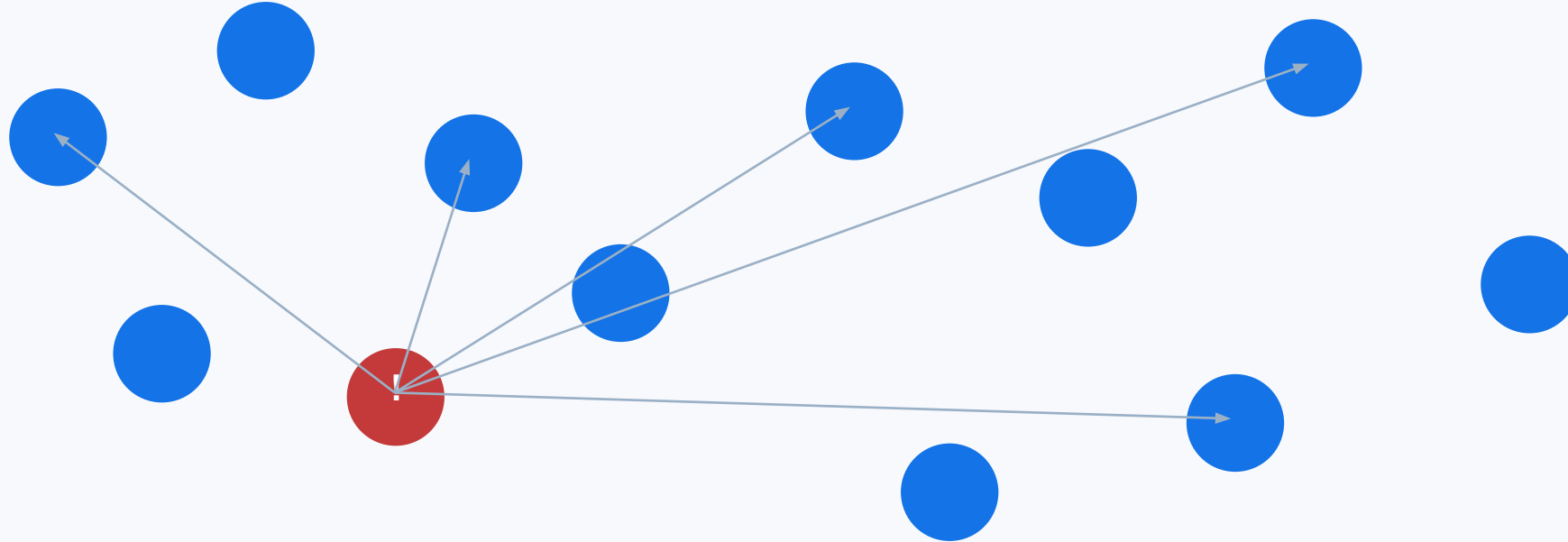
MATÉRIEL

Side-channel
Fault injection
Hardware Trojan

Exemple simple Un modèle peut être trompé par une entrée, corrompu par son apprentissage, ou perturbé au niveau de la puce qui l'exécute.

Exemple : attaque sur une meute de drones

Dans un système collectif, un seul nœud compromis peut influencer tout le groupe.



1. Compromission

Un drone transmet de fausses positions.

2. Propagation

Les voisins font confiance à l'information.

3. Effet collectif

Trajectoires modifiées, dispersion, collisions.

Le hardware peut aussi protéger l'IA

Performance et sécurité peuvent partager la même base matérielle.

Applications / IA

Modèles et logique métier

Runtime / OS

Isolation, permissions, mémoire

Boot & firmware

Secure Boot, signatures

Hardware trust

TPM, enclave, modules cryptographiques

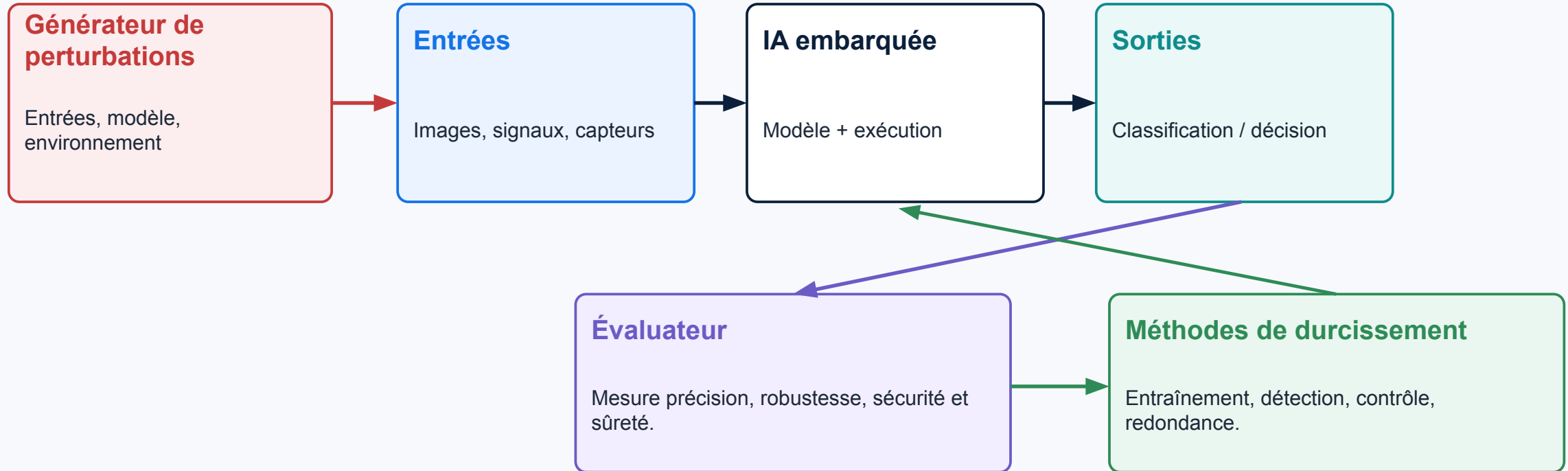
Accélération

GPU / NPU / accélérateurs IA

La sécurité matérielle fournit une racine de confiance pour protéger clés, modèles et exécution.

Évaluer la robustesse : perturber, mesurer, durcir

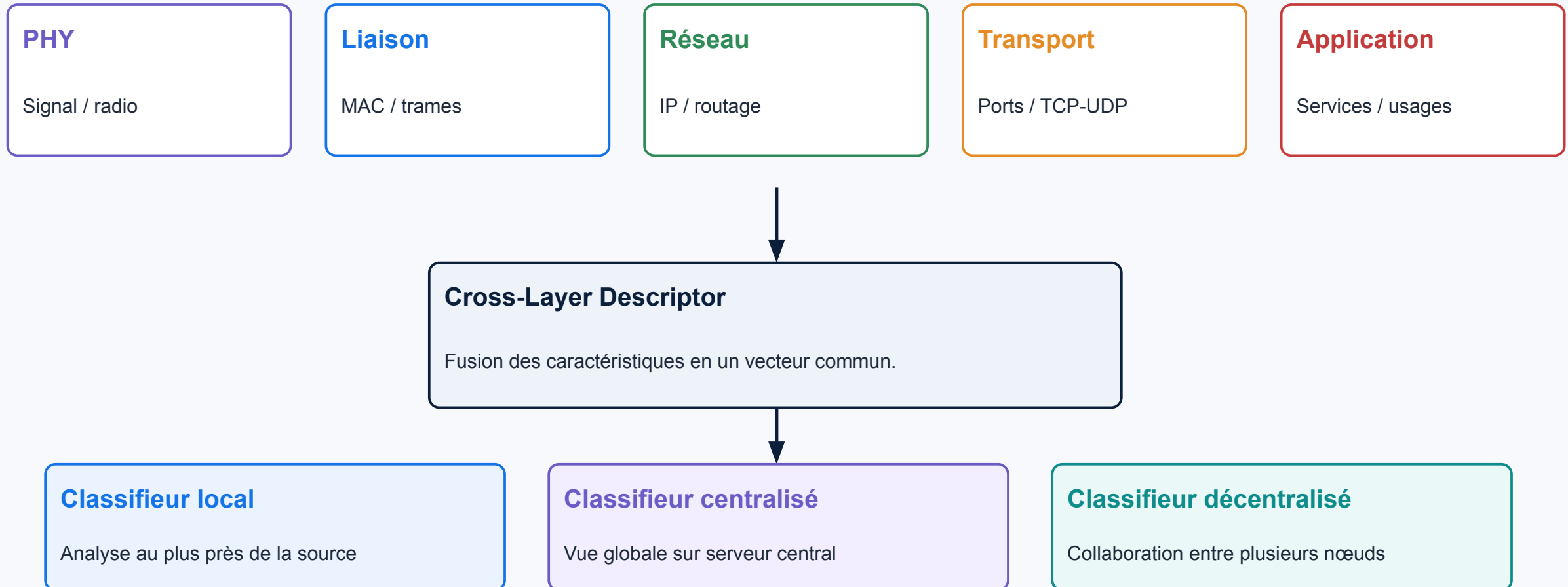
Une méthode cyclique pour tester Security et Safety.



On ne cherche pas seulement une bonne précision, mais un comportement fiable sous perturbation.

Cross-Layer IDS : voir le système dans son ensemble

La détection combine plusieurs couches au lieu d'observer un seul niveau.



Conclusion : sécuriser l'IA, c'est protéger toute la chaîne — capteurs → données → modèle → matériel → décision → action physique.

PARTIE 4

Résilience des NIDS basés sur le Machine Learning

Synthèse visuelle construite à partir des documents fournis

Des IDS à signatures aux NIDS basés sur le ML

Le changement clé : passer de « je reconnais une attaque connue » à « je détecte un comportement qui sort de la normale ».

01 NIDS classique

- Règles et signatures connues
- Très efficace sur les attaques répertoriées
- Faible capacité à détecter l'inconnu

02 ML-based NIDS

- Apprend des patterns de trafic
- Détecte anomalies et comportements inhabituels
- Peut repérer des menaces sans signature

03 Nouveaux risques

- Faux positifs / faux négatifs
- Data drift et label shift
- Data poisoning et attaques adversariales

Le gain de détection s'accompagne d'un nouveau défi : maintenir la fiabilité du modèle quand le réseau change.

Pourquoi le réseau réel met le modèle à l'épreuve

Les performances observées en laboratoire ne se transposent pas automatiquement en production.

Diversity of network traffic

Trafic très varié, donc difficile à modéliser correctement.

Outlier detection

Détecter ce qui sort de la norme sans confondre nouveauté et attaque.

Semantic gap

Une anomalie statistique n'est pas forcément une attaque réelle.

High cost of errors

Une erreur peut bloquer un service légitime ou laisser passer une attaque.

Lab-only evaluation

Un environnement trop contrôlé peut surestimer la performance réelle.

Adversarial setting

L'attaquant cherche activement à tromper ou contourner le modèle.

Le cœur du problème : un modèle ML apprend un instantané du réseau, alors que le réseau réel continue d'évoluer.

Data drift : quand la réalité ne ressemble plus à l'entraînement

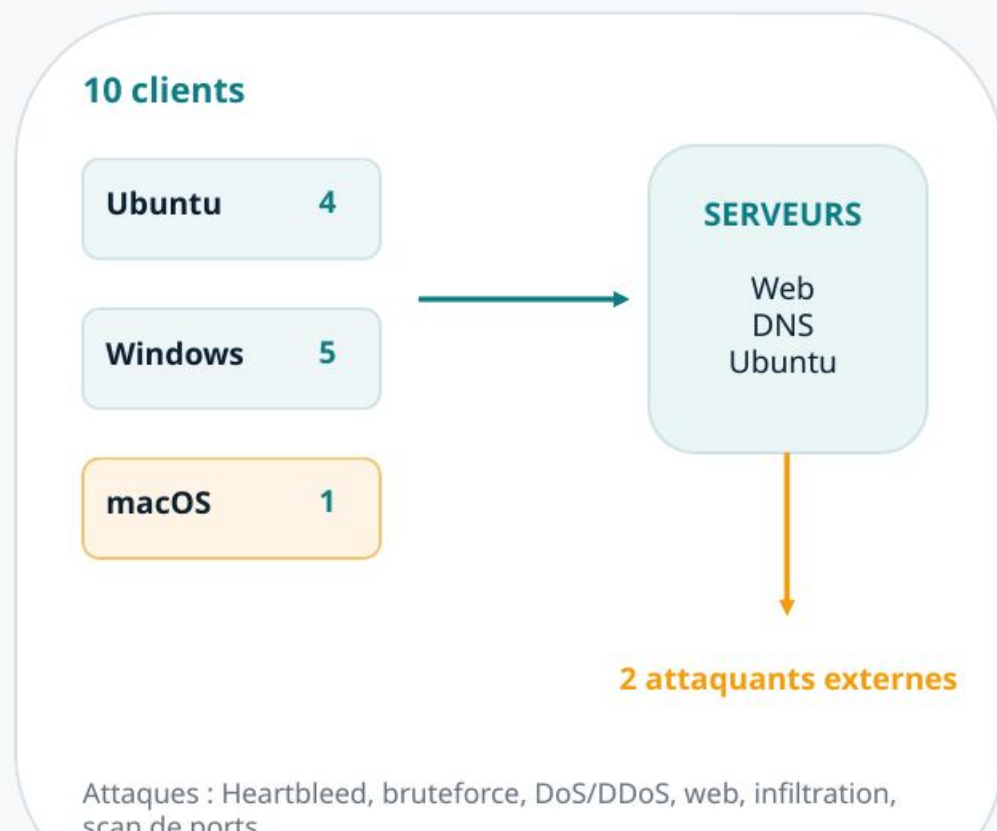
Nouveaux hôtes, nouveaux protocoles ou nouveaux usages déplacent la distribution des données en production.



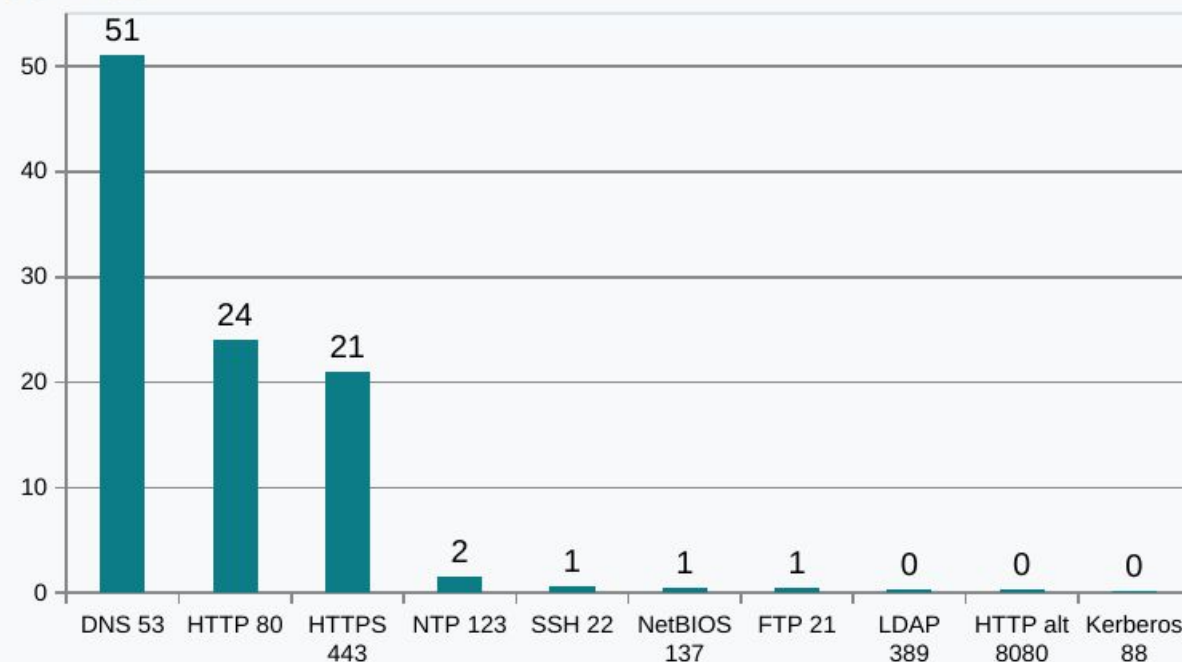
Question : comment le data drift causé par de nouveaux hôtes ou protocoles affecte-t-il un NIDS entraîné en « closed world » ?

Un environnement réseau réaliste pour provoquer le drift

Le dataset mélange trafic utilisateur légitime, plusieurs OS, services réseau et attaques connues.



Répartition des flux par service



DNS + HTTP + HTTPS représentent environ 96 % des flux : le dataset est fortement déséquilibré.

Du paquet au score d'anomalie

Le NIDS travaille sur des flux résumés en caractéristiques numériques, puis un autoencodeur mesure leur étrangeté.



Plus l'erreur de reconstruction est élevée, plus le flux s'éloigne de ce que le modèle considère comme « normal ».

Comment simuler l'arrivée d'un élément inconnu

On retire volontairement un hôte ou un protocole de l'entraînement et de la validation, puis on le réintroduit au test.

Dataset complet



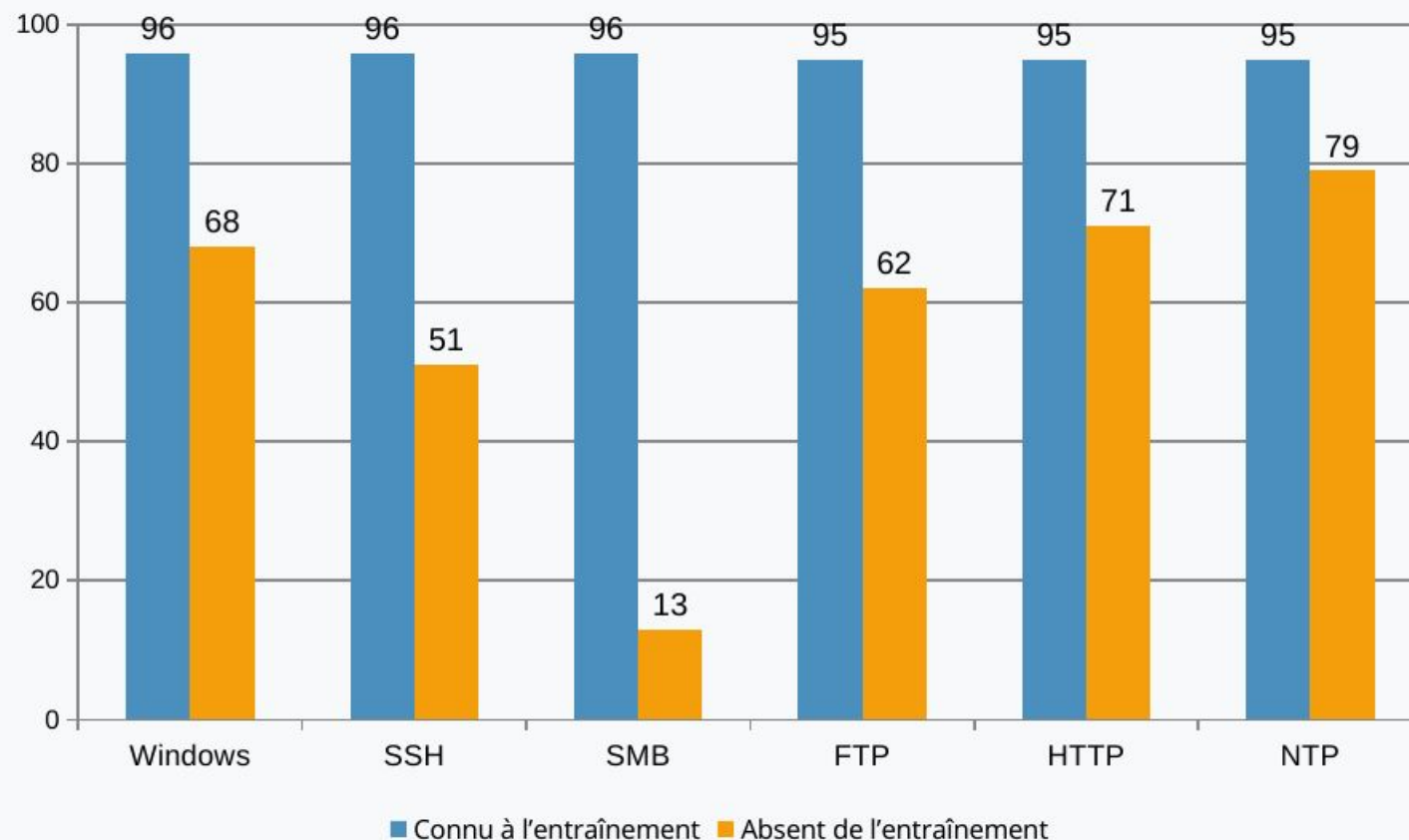
Scénarios de drift



Le test reproduit un vrai "jour 1" : le modèle découvre en production un trafic légitime qu'il n'a jamais appris.

Quand l'élément est absent de l'entraînement, la précision chute

La baisse est très variable selon l'élément : le data drift n'affecte pas tous les protocoles de la même manière.



! **SMB : cas extrême**
≈ 96 % → 13 %

↓ **SSH**
≈ 96 % → 51 %

↓ **Windows**
≈ 96 % → 68 %

Un NIDS peut sembler excellent en labo, puis perdre brutalement en précision à l'arrivée d'un hôte ou protocole inédit.

Le piège des métriques globales

Un score global peut rester bon alors qu'une catégorie entière est mal classifiée.

F1 global	Précision sur l'élément nouveau	
Baseline	0.87	—
Windows	0.71	68 %
Mac	0.89	76 %
SSH	0.90	51 %
SMB	0.89	13 %

Exemple SMB

F1 global

0,89

Précision SMB

13 %

Le tableau de bord global peut donner une illusion de stabilité pendant qu'un protocole devient presque inutilisable.

Il faut suivre la performance par hôte, protocole et catégorie, pas seulement une moyenne globale.

Tous les data drifts ne se valent pas

Une hausse du volume de trafic est ici bien mieux absorbée qu'un nouvel hôte ou un nouveau protocole.

Scénario	ACC	F1	FPR	FNR
Baseline	0,95	0,87	0,04	0,12
+10 %	0,93	0,83	0,05	0,14
+50 %	0,93	0,83	0,05	0,11



Lecture

+10 % et +50 % de débit :
les métriques bougent peu.



Pourquoi ?

La normalisation par quantiles amortit ces
variations de même ordre de grandeur.

Dans cette étude, le changement d'hôte ou de protocole est plus critique qu'une simple variation de volume.

Conclusion : le modèle apprend le passé, le réseau continue d'évoluer

La résilience d'un NIDS ML ne se résume pas à sa précision initiale : elle dépend de sa capacité à rester fiable dans le temps.



Ce que montre l'étude

- Nouveaux hôtes/protocoles → forte dégradation locale
- Les métriques globales peuvent masquer le problème
- Le débit seul a ici un impact limité



Ce qu'il faut surveiller

- Drift de données
- Faux positifs / faux négatifs
- Performance par catégorie
- Évolution de l'infrastructure



Ce qu'il faut construire

- Benchmarks de résilience
- Apprentissage continu
- Datasets évolutifs
- Explicabilité pour les analystes

3 mots pour retenir

ROBUSTESSE

ADAPTATION

EXPLICABILITÉ

« Un bon NIDS n'est pas seulement celui qui détecte bien aujourd'hui, mais celui dont on comprend quand et pourquoi il cessera de bien détecter demain. »